

## API Security Requirements

### Purpose

The purpose of this document is to define the security requirements for the SecOpsAI API and ensure secure access to system resources.

### Authentication

- All API users must authenticate before accessing protected resources
- JWT tokens will be used for authentication
- Tokens must expire after a defined period
- Invalid or expired tokens must be rejected

### Authorization

- Role based Access Control (RBAC) shall be implemented
- Users shall only access resources permitted by their assigned role
- Administrative functions shall be restricted to authorized users

### Data Protection

- All API communication shall use HTTPS
- Sensitive information shall not be exposed in responses
- Secrets and credentials shall be stored securely.

### Input Validation

- All users shall be validated on the server side.
- Invalid requests shall be rejected
- Input validation shall help prevent injection attacks.

### Rate Limiting

- API requests shall be rate limited
- Excessive requests shall be blocked or throttled
- Rate limiting shall help protect against abuse

### Logging and Monitoring

- Authenticate attempts shall be logged
- Failed access attempts shall be recorded
- Security events shall be monitored

## Conclusion

These requirements provide a baseline level of protection for the SecOpsAI API and support secure operation of the platform.